PAGE No
DATE / /

CASE STUDY - 1

Brightmart is a medium sized online shopping company customers used its website & mobile application to purchase products

The company stores

Customers names
Email Addres
phone Numbers
Delivery Addresses
passwords
order Information
payment related information

Brightmart has around 100 Employees

The company recently hired several new employees to make things easier the IT department gave employees access to different internal System.

However, the company has the following Security weakness

Some employees use simple passwords such as brightmart1
Many employees use the same password for multiple systemes.

- Software updates are sometimes delayed
- The company does not regularly conduct employee cybersecurity training.
- There is no multi factor authentication for some important accounts.
- Employee can access sensitive information that they do not necessarily need for their jobs
- Backups are performed any once a month

The incident

One monday morning an employee named Rahul receives an email:

Subject : Urgent - Your Account will be Suspended

The email appears to come from the company IT department

it says :

"Your company account will be Suspended today click the link below and Verify your password immediately.

Rahul clicks the link.

PAGE No.
DATE / /

The page looks almost identical to the company's login page.

He enters his username & password.

Rahul does not realize that the website is controlled by an attacker.
The attacker now has Rahul's login credential

Stage I - Unauthorized Access

The attacker uses Rahul's credentials to access BrightMart's internal System.

Because Rahul uses the same password for another System, the attacker is also able to access that System.

The attacker discovers that Rahul has access to customer information.

The attacker downloads a large amount of customer data.

What Cybersecurity problem has occurred?

Stage 2 - Malware Attack

The attacker sends another email to Rahul containing a malicious attachment.

Rahul opens the attachment.

Malware is installed on his computer.

The malware begins communicating with the attacker's system.

The attacker now attempts to move from Rahul's computer to other systems within Ponghkart's network.

Question
Which vulnerability allowed the attacker to move further into the organization.

Stage 3 - Ransomware

Two days later employees arrive at work & discover that they cannot access important files.

A message appears on their computer.

"Your files have been encrypted. Pay the ransom to recover them."

PAGE No
DATE / /

The company's customer database & several important business files are encrypted.

Unfortunately the company's most recent backup is almost a month old.

Bright Mart's website stop working

Customers cannot place orders.

The customer support team cannot access customer records.

Stage 4 - Business impact

BrightMart now face several problems

Financial Impact

The company loses sales because its website is unavailable.

Data Impact

Customers information may have been stolen

Operational Impact

Employees cannot access important System

Reputation Impact

Customer lose confidence in the company

Legal / compliance Impact

The company may face regulatory or legal consequences depending on what information was exposed and which law apply

Group 1 - Identify the threats

What threats are present in this case?

Group 2. Identify the Vulnerabilities

What weakness in Bright Mart's Security allowed the attack to succeed?

Group 3 Apply the CIA Triad

Was confidential information exposed? Was information changed or damaged? Were systems available to legitimate users?

Group 4 - Security Solutions

Question 1

Who is responsible for Cybersecurity

PAGE No
DATE

Question 2.
Was phishing the only problem?

Question 3.
What was the biggest vulnerability?

Quiz Assessment.

At the end, ask Students to answer the 5 quiz.

1. What was the initial attack against BrightMart?
2. Give three vulnerabilities that helped the attackers.
3. Which three Security principles of the CIA Triad were affected?
4. What was the impact of the ransomware on BrightMart?
5. Suggest three security controls BrightMart should implement.

Sol^n

* What cybersecurity problem has occurred?
→ phising
Credential theft
Unauthorized access
Data breach

Question:
which vulnerability allowed the attacker to move further into the organization?
Students should identify possibilities such as:
weak passwords
Excessive user privileges
Lack of MFA
poor network security
Lack of employee awareness
Outdated Software

What threats are present in this case?
They may identify
phishing
Malware
Ransomware
Credential theft
Unauthorized access
Data theft

What weakness in Brightmart Security allowed the attack to succeed?

Expected answers.

Vulnerability	How it helped the attackers
Weak passwords	Easier to compromise accounts
password reuse	One stolen password give access to multiple system.
. NO MFA	Stolen password may be enough to log in.
. Lack of training	Employee fall for phising.

Vulnerability	How it helped the attackers
Delayed update	Vulnerable Software may be exploited
. Excessive privilege	Attackers can access more time
~~Infrequent backups~~	Difficult to recover after ransomware

PAGE No.
DATE / /

Ask Students to determine how the attack affected.

Confidentiality
Was confidential information exposed?
Yes.
Customer information was accessed/downloaded by the attacker.
Integrity
Was information changed or damaged?

~~Vulnerability~~ ~~How it helped the attacker~~

~~delayed updates~~ ~~Vulnerable software may be exploited~~

~~Evasive~~ ~~Attacker can access more data~~
~~Pivoting~~
~~Infrequent backups difficult to recover after ransomware~~

~~Ask Students to determine how the attack affected.~~
Confid

Was information changed or damaged?
Potentially yes.

The attackers could modify or encrypt files.

PAGE No.
DATE / /

Availability
Were System available to legitimate users:
No
The website & internal Systems became unavailable because of ransomware
So:
Confidentiality → Affected
Integrity → Affected
Availability → Affected

Group A Security Q1:

What should BrightMart do to prevent this from happening again?
Students could suggest

Use Strong passwords
Implement Multi-Factor Authentication (MFA)
provide regular cybersecurity awareness training
conduct phising simulation exercises
Keep software updated
Follow the principle of least privilege
Segment important networks
Maintain regular backups.
Encrypt Sensitive data
Deploy antivirus / endpoint protection.
Monitor Suspicious login activity

Develop an incident response plan

Who is responsible for cybersecurity?
Expected discussion.
Not only IT department. Every employee who uses the organisation's system has a role in cybersecurity

Question 2

Is it phishing the only problem?
NO
phishing was the initial attack, but weakness such as password reuse lack of MFA excessive privileges poor backups & insufficient training allowed the attack to become much more damaging

Question 3

What was the biggest vulnerability
There is no single correct answer.
Students should justify their choice

For example

"Lack of employee awareness was a major influencing factor as the attacker started with a phishing email. Had the

Case study: 2.

Securing the University Examination System

1 University uses an Operating System - based examination management system to store student records examination marks, faculty details and question papers. The system has three main user groups: Students, faculty and Administrator. Students should be able to view only their own marks and download permitted learning materials. faculty members need to view student record. Administrator manages user accounts permissions & system configuration.

The University has assigned permissions through roles, but an audit review identifies the following events:

At 10:00 the account student student07 has three failed login attempts.

At 10:03, Student07 successfully logs in.
At 10:03, student07 successfully logs in.
At 10:04 student07 attempts to open ExamMarks.xlsx which contains marks for an entire class.
At 10:07 the system records an attempted modification of Exam Marks.xlsx by student07.
At 10:15, faculty02 modifies marks in Exam Marks.xlsx and saves the file successfully.

PAGE No
DATE 1 1

At 10:20, an administration discovers that a former faculty member's account is still active.

The audit log is stored on the same server and user with broad permissions may be able to modify or delete it.

The university want to protect confidentiality, integrity and availability prevent unauthorized access implement access control security administration and auditing measures.

Question:

Q1 Identify the main security problems in the case study (4marks)

List at least four risk or weakness indicated by the scenario.

Q2 Explain the difference between authentication and authorization using Edmodo as an example (4mark)

Distinguish identity verification from permission checking.

PAGE NO
DATE / /

03.] Recommend an access control policy for students faculty and ~~Admins~~ Administrators. Justify your choice. (5 marks)
~~or~~ Consider how permissions should be designed and managed

04] prepare a suitable Access list (ACL) for ExamMarks.xlsx. (5 M)
Specify appropriate Read, write and Delete permission for each user group

05] ~~Interpret the audit events from 10:00~~
Explain the principle of least privilege should be applied in this system. State what each group needs to do and which unnecessary permissions should be removed.

06] Interpret the audit events from 10:00 - 10:05
What should the Security team do next?
Explain why the sequence is suspicious without assuming that it is an attack.

07] Identify at least 5 events that should be recorded in the audit log. Include file access permissions and administrative events.

Ans

Ans: The main security problem in the unsecure access control system are:

a. ~~Weak~~ ~~Authe~~ poor for Access control
Poor Account Management
poor Security and
Insecure Audit log Storage

A2 Authentication

It is used to check whether the user is legal or not. In other words check its Identity.

Authorization

It gives the permission or privilege to the user on what he/she is allowed to do with that file

The login process of 3 failed attempt the attempt to access the file and then Successful login, comes in its come in this process.

Identity Verification is the "who" of OS whereas permission checking is the the "what" of the OS

PAGE No.
DATE / /

A3. The most suitable Access Control policy is role Based Access Control (RBAC) as its purpose is to give permission according to the role assigned therefore with this Student can only read marks faculty can only write marks admin can do anything

A4 The ACL for the above case study is:

User	modification	Read	Permission on the Records
Student	Deny	Allow	Allow
Faculty	Deny	Allow	Allow
Admin	Deny	Allow	Allow

A5. Principle of least privilege (polp) is a rule that states the user and program should only have the minimum access necessary to complete their specific task.

User	Required permission	Unnecessary permissions with modify access
Student	Read only	
Faculty	View write	Can only modify marks & System permissions
Admin	Manage Modify access	

A6 The Event that start at 10:00 o'clock
there were 3 Failed login and one after
Successful login can not the considered
as suspicious or it might be a human
error but after that when it escalated
to modify the the marks Should
trigger the warning as escalated to
the immediate steps team of Security
Should them
- Suspend of free the student Account
- Terminate all Active Session
- Contact the actual Student about it
- Examine networks

A7. The 5 Security that must be recorded
are
- Authentication Events (Successful or failed
logins)
- File and Data Access Events (Read modify
delete etc)
- Account Creation modification & deletion
- Changes made to role
- Changes made with Security

A8. Audit Logs purpose is to save history
for everything that happens inside the
computer System.

- It will prevent attacks cover ups
- Ensure there is repudiation.
- Can help to identify when who or the attack occur from

It can be protected by:
- Storing the log in a place other that site
- Encrypting the logs by having or Singing it.

A9. The active account of the ex faculty member must immediately disable and systemically deprovisied. As keeping it open will indicate the lack of principle of least privilege. The ghost account also creates a security hazard.

A10 The plan for the University to fix this problem is:

1. Interrogate the Student teacher activity
2. Block the faculty account and lockdown the file.
3. Make new policy with it comes Hand-
4. Set up alerts and do periodical checks